SCOPE OF WORK & TECHNICAL BRIEF

RFP / SECURITY BRIEF

Confidential

Web Application Penetration Testing

TARGET SYSTEM	ORGANIZATION	ASSESSMENT TYPE	PRIMARY CONTACT
Clockwork Control	**Clockwork Web Dev, LLC**	**Grey-Box (Web App & API)**	**Aaron Reimann (Owner)**

1. Overview & Project Objective

Clockwork Control is a centralized fleet management, monitoring, and orchestration platform that maintains over **240 WordPress client websites** and tens of cloud and bare-metal servers. The application acts as the central command node for client fleet updates, remote telemetry, database backups to Amazon S3 Glacier, synthetic contact form deliverability testing, automated threat detection, and remote system administration.

Because Clockwork Control stores sensitive infrastructure secrets—including encrypted SSH keys, database credentials, third-party API tokens, and cryptographic HMAC signing keys—the application represents a high-value operational target.

> **Engagement Objective**
>
> Evaluate Clockwork Control against modern attack vectors, focusing primarily on **business logic vulnerabilities, remote command execution paths, authorization bypasses, and inter-service authentication** across the platform's actively enabled modules.

2. Architecture & High-Priority Scope

The system is built on **Laravel 12 (PHP 8.4+, MySQL 8)** with a modular architecture. Control communicates bidirectionally with remote WordPress sites via a signed HMAC-SHA256 REST API (the *Clockwork Companion* and *Clockwork Renegade* plugins) and connects to cloud providers via REST APIs and SSH.

Testing Focus: Assessors must prioritize the **currently active modules** below. Inactive or unused modules should not receive testing hours.

ACTIVE MODULE	ARCHITECTURAL FUNCTIONALITY	PRIMARY THREAT VECTORS & CONCERNS
Code Snippets `code-snippets` Critical Risk Area	Allows administrators to dispatch and execute arbitrary PHP code snippets remotely across WordPress client sites.	• Authorization bypass (non-admin execution) • Host command injection & remote code execution (RCE) • Sandbox escaping or unhandled execution outputs • Cross-tenant snippet leakage

ACTIVE MODULE	ARCHITECTURAL FUNCTIONALITY	PRIMARY THREAT VECTORS & CONCERNS
Backup Relay `backup-relay`	Direct S3 Glacier streaming, manifest sidecars, backup archive enumeration, download generation, and restore staging.	• S3 presigned URL forgery or scope expansion • Path traversal during archive unpack/staging • Unauthorized download or restore trigger of client backups • AWS credential leakage
TurnkeyWP Control `turnkeywp`	Clockwork's hosting control plane: executes remote commands over direct SSH connections to Linux VPS servers.	• Command injection via unsanitized arguments • Harvesting stored SSH credentials (`ssh_private_key`) • Unauthorized command dispatch across host servers
Gatekeeper & SSO `gatekeeper`	Fleet-wide brute-force defense, 2FA enforcement, and single-click administrative SSO link generation into WordPress sites.	• SSO token manipulation, forgery, or replay • 2FA requirement bypass • Lockout manipulation or denial-of-service against valid users
Exploit Shield `exploit-shield`	Real-time honeypot & probe defense, exploit log analysis, and automated firewall/iptables IP bans.	• Evasion of probe signature detection • Denial-of-service via forged IP spoofing to trigger bans • Command injection into iptables / firewall runners
Site Maintenance `site-maintenance`	Remote maintenance mode toggling and secret key bypass tokens across client sites.	• Unauthorized locking or unlocking of client production sites • Maintenance token brute-force or leakage
Client Reports `client_reports`	Automated monthly maintenance report compilation, email dispatch, and client recipient synchronization.	• Stored Cross-Site Scripting (XSS) in email previews / HTML • Insecure Direct Object References (IDOR) in report history • Email header injection during automated delivery
Authentication Suite `email-auth` / `auth_google`	Email/password local login and Google OAuth SSO enforced strictly against an internal database allowlist.	• Allowlist bypass (logging in with valid Google account not on allowlist) • Session fixation, session hijacking, or improper session invalidation upon user revocation
Host Adapters `pressable` / `spinupwp`	API client adapters and command execution runners for SpinupWP (SSH) and Pressable (async command API).	• API token scope escalation • Staged tarball tampering during plugin updates
Form Testing & Diagnostics `contact-forms` / `ai-remedy`	Synthetic form submission testing and AI-driven log analysis / remediation suggestions.	• Server-Side Request Forgery (SSRF) via form test targets • Prompt injection and unauthorized data exfiltration via LLM

Explicitly Out-of-Scope (Do Not Test)

- **Inactive Modules:**
  `linode`, `wpengine`, `kinsta`, `cloudways`, `slack`, `client_slack`, `auth_github`, `auth_microsoft`, `gridpane`, `llar`, `feedback`.
- **Third-Party Infrastructure:**
  DoS/DDoS volumetric attacks against cloud providers (AWS, DigitalOcean, Hetzner, Pressable, Cloudflare).
- **Physical & Social Engineering:**
  Physical attacks against facilities, phone phishing, or social engineering targeting agency employees.

3. Core Vulnerability Focus Areas

The penetration tester will evaluate the application against the OWASP Top 10 and specialized architecture risks:

- **1. Remote Code & Command Execution:** Validate that non-administrators or external callers can never trigger code execution in `code-snippets`, `turnkeywp`, or via the Pressable Command Runner.
- **2. Inter-Service HMAC Authentication:** Test the integrity of signed REST requests between Clockwork Control and the WordPress Companion/Renegade plugins (`X-Clockwork-Signature` and `X-Clockwork-Signature-V2`). Assess replay resistance (5-minute window), timing attack resilience, and canonical query parameter tamper resistance.
- **3. Authorization & Strict Allowlist Controls:** Test role-based access control (RBAC) separating `admin` and `operator` roles. Verify that the `EnsureUserIsActive` middleware immediately revokes access across all modular routes when a user is deactivated.
- **4. Cryptographic Storage & Secrets Handling:** Verify that AES-256-GCM encrypted columns (`servers.ssh_private_key`, `sites.db_password`, `sites.companion_secret`) are never disclosed via error stack traces, API serialization, or client-side payloads.
- **5. Injection (SQLi, XSS, SSRF):** Evaluate input validation across search filters, batch update actions, telemetry log streams, and synthetic form testing endpoints.

4. Engagement Logistics & Methodology

- **Assessment Type:** Grey-Box Penetration Test. The tester will be supplied with staging credentials (both Admin and Operator tiers) and read-only access to the application source repository for code-assisted analysis.
- **Testing Environment:** Testing will be conducted against a **dedicated staging/lab instance** replicating production configuration, populated with non-sensitive test data. Testing against live client production websites is prohibited.
- **Safe Harbor:** Clockwork Web Dev, LLC authorizes all activities conducted in good faith within the scope and rules of this brief.
- **Vulnerability Disclosure:** If a Critical / Zero-Day vulnerability is uncovered (such as unauthenticated RCE), the tester must report it immediately within 24 hours to the primary contact prior to report publication.

5. Required Deliverables

1. **Executive Summary:** High-level overview of security posture, key risks, and business impact tailored for leadership.
2. **Detailed Technical Report:**
   - Vulnerability classification with CVSS v3.1 scores.
   - Affected module, route, parameter, or source code file.
   - Step-by-step reproduction steps with Proof-of-Concept (PoC) code or requests.
   - Specific, actionable remediation instructions tailored to Laravel / PHP.
3. **Remediation Review & Re-Test:** A follow-up re-test to confirm successful remediation of identified issues after patches are deployed.

6. Proposal Submission Instructions

Security consultants and penetration testing firms interested in this engagement are invited to submit a brief proposal including:

- **Firm/Consultant Qualifications:** Demonstrated experience in Laravel, PHP, and cloud API / orchestration platforms.
- **Testing Approach & Tooling:** Mix of automated tooling vs. manual business-logic testing.
- **Timeline & Availability:** Estimated turnaround time (typical expectation: 2 to 3 weeks).
- **Cost & Engagement Terms:** Fixed-fee quote, including re-testing validation.
- **Sample Report:** An anonymized or redacted sample finding from a previous application assessment.

> **Submission Contact**
> Please send proposals and inquiries to:
> **Aaron Reimann**
> • Email:
> **aaron.reimann@gmail.com**
>
> Subject: `[Penetration Testing Proposal] Clockwork Control Security Assessment`